Universidad Rafael Landívar

Facultad de Ingeniería

Ingeniería en Informática y Sistemas

Ingeniería de Software I · Proyecto final 2026

Shapi

Documento de Requisitos

Plataforma como servicio para publicar APIs, controlar su uso y cobrar por ellas

Héctor Jordin Adolfo García Coyoy	2427124
Ronaldo Emilio Méndez Mayorga	1563224
Dominique Guillermo Contreras Sierra	1508224
José Pablo Zúñiga de León	1507524

Quetzaltenango, Guatemala

25 de octubre de 2026

Índice

Seleccione un capítulo o sección para ir a su contenido. El PDF también incluye marcadores de navegación.

01 · Visión y alcance

1. Introducción

1.1 Objetivos

2. Categoría del enunciado

3. Problema y justificación

4. Actores

5. Descripción del funcionamiento

6. Modelo de negocio

7. Alcance

8. Restricciones

02 · Glosario

Formatos

03 · Requisitos

1. Requisitos funcionales

2. Requisitos no funcionales

3. Trazabilidad con los lineamientos

4. Cambios respecto al documento del 11 de septiembre

04 · Roles y permisos

1. Ámbitos de identidad

2. Roles

3. Matriz de permisos

4. Reglas adicionales

05 · Casos de uso

1. Diagramas de casos de uso

2. Especificaciones

01 · Visión y alcance

> Fuente de verdad del proyecto. Sustituye a la propuesta y al documento de requisitos y diseño que se entregaron a la docente (28 de agosto y 11 de septiembre de 2026). Las reglas del curso están en `../lineamientos.md`.

1. Introducción

Shapi es una plataforma como servicio que permite a una empresa **publicar su API, controlar quién la usa y cobrar por ella, sin modificar el servidor que ya tiene**. La empresa conecta su servidor, sube su especificación OpenAPI y define planes. Shapi le crea un portal con la marca de esa empresa, emite las claves de acceso, aplica las cuotas en cada petición y registra el consumo y los pagos.

Proyecto final de Ingeniería de Software I, Universidad Rafael Landívar, campus de Quetzaltenango, 2026.

Integrante	Carné	Responsabilidad
Héctor Jordin Adolfo García Coyoy	2427124	Coordinación y compuerta de tráfico
Ronaldo Emilio Méndez Mayorga	1563224	Usuarios, planes, suscripciones y pagos
Dominique Guillermo Contreras Sierra	1508224	Interfaz de usuario y portales de marca blanca
José Pablo Zúñiga de León	1507524	Infraestructura, despliegue, pruebas y documentación

1.1 Objetivos

Objetivo general: diseñar, desarrollar, documentar e implementar una plataforma como servicio que permita a una empresa publicar su API, administrar a sus consumidores mediante planes y claves de acceso, y cobrar por su uso desde un portal con su propia marca.

Objetivos específicos:

1. Levantar los requisitos funcionales y no funcionales del sistema y modelar los casos de uso de sus actores: proveedor, consumidor, administrador, soporte y sistema (03, 05).
2. Diseñar la arquitectura, el modelo entidad-relación y la base de datos, y justificar cada decisión (06, 07, 12).
3. Implementar la gestión de usuarios: registro, verificación de correo, recuperación de contraseña, autenticación con sesiones y control de roles, tanto para el personal como para los consumidores.
4. Desarrollar la compuerta de tráfico: validar claves, aplicar límites por minuto y cuotas, y medir el consumo de cada consumidor (08).
5. Implementar las suscripciones y los pagos: ver planes, contratar, historial de pagos, renovación automática, gracia y suspensión, con una pasarela simulada (09).
6. Generar automáticamente, a partir de la especificación OpenAPI de cada proveedor, un portal de marca blanca con documentación y consola de pruebas.

7. Desplegar el sistema en un ambiente productivo simulado y reproducible, y elaborar el manual técnico y el manual de usuario.

2. Categoría del enunciado

De las tres categorías del enunciado se eligió **Servidores Web como Servicio**. La propuesta ya fue **aprobada por la docente**.

El recurso que se contrata es un **entorno web gestionado por API**, que Shapi crea, configura y monitorea desde una interfaz web. Cada entorno tiene:

- un subdominio para el portal y otro para la API, ambos con certificado TLS;
- el enrutamiento hacia el servidor de origen, con las rutas que el proveedor decide exponer;
- un portal web alojado por la plataforma;
- el monitoreo de peticiones, latencia, errores y datos transferidos.

Lo que exige el enunciado (opción C)	Cómo lo cumple Shapi
Crear entornos web	Cada API registrada crea un entorno con subdominio, certificado, rutas y portal (RF-08 a RF-11)
Gestionar configuraciones	Origen, rutas, límites, caché, planes, claves, marca, dominio propio y secreto de origen
Gestión de dominios simulados	Subdominios bajo `shapi.localhost` y dominios propios verificados con un DNS simulado (06 · Arquitectura)
Monitorear consumo de recursos	Peticiones, llamadas, latencia p95, errores por código y bytes transferidos (RF-35)

3. Problema y justificación

Una empresa que ya tiene un servicio funcionando puede convertirlo en un ingreso. Pero entre un servidor que responde y un producto que alguien pueda contratar siempre hay que construir lo mismo: claves, límites de uso, medición, documentación, planes y cobro. Esa parte no diferencia a nadie y cuesta semanas de trabajo.

Hay plataformas internacionales que ya lo resuelven, pero cobran a través de pasarelas que no admiten empresas guatemaltecas, o imponen su marca y se quedan con una comisión del 20 % al 25 %.

Alternativa existente	Modelo de cobro	Limitación en Guatemala
Puertas de enlace con monetización integrada	Suscripción mensual	Liquidan por una pasarela que excluye a Guatemala
Plataformas de tienda de API	Suscripción mensual	El mismo obstáculo, y la interfaz y el soporte solo están en inglés
Mercados centralizados de API	Comisión del 20 % al 25 %	Imponen su marca y se quedan con la relación con el cliente

Propuesta de valor de Shapi:

- Cobra una suscripción fija, sin comisión.
- Conserva la marca del proveedor.
- Su interfaz está en español.
- **El cobro queda detrás de una interfaz de pasarela de pagos** (`IPasarelaPagos`). En esta versión académica esa pasarela es un **simulador**, como permite el enunciado. La arquitectura permite conectar después una pasarela local sin cambiar el resto del sistema (ADR-12).

4. Actores

Actor	Quién es	Dónde trabaja
Proveedor	La empresa que publica y cobra su API. Es el **cliente** de Shapi y corresponde al rol "Cliente" del enunciado. Dentro de su organización, cada persona es propietario, editor o lector.	Panel de Shapi (`shapi.localhost/panel`)
Consumidor	El desarrollador o la empresa que contrata un plan y usa la API. **Su cuenta pertenece a la organización proveedora**; no se registra en Shapi.	Portal de marca blanca (`{sub}.shapi.localhost`) y la API (`{sub}.api.shapi.localhost`)
Administrador	Quien opera la plataforma. Corresponde al rol "Administrador" del enunciado.	Panel de administración (`shapi.localhost/admin`)
Soporte	Quien atiende los casos de los proveedores. Tiene acceso de **solo lectura** a los datos de las organizaciones. Es uno de los roles opcionales del enunciado.	Panel de administración, con menos opciones
Sistema	Los procesos automáticos: la compuerta y el trabajador en segundo plano.	Sin interfaz

El administrador y el soporte entran por el mismo formulario de inicio de sesión que el proveedor, y el sistema los enruta según su rol. No tienen registro público: la primera cuenta de administrador se crea en la siembra inicial del sistema.

5. Descripción del funcionamiento

Uso por parte del proveedor

1. Se registra, confirma su correo y su organización queda en el plan **Prueba** (30 días, sin tarjeta).
2. Registra una API con un nombre, la URL de su servidor de origen y un **subdominio** que él elige. Shapi prueba la conexión con el origen antes de guardar.
3. Sube su especificación OpenAPI. Shapi extrae las rutas y el proveedor decide cuáles expone.
4. Configura cada ruta: límite por minuto, caché y peso en llamadas. También personaliza el portal: logotipo, color, nombre y texto de bienvenida.
5. Define los planes de su API y la publica.
6. Consulta el consumo, la facturación por consumidor y su historial de pagos. Puede invitar miembros, invitar consumidores y abrir casos de soporte.

Uso por parte del consumidor

1. Entra al portal del proveedor, revisa la documentación y crea su cuenta, o acepta una invitación.
2. Confirma su correo, elige un plan y paga con tarjeta. Los planes gratuitos no piden tarjeta.
3. Recibe **una clave de producción y una de pruebas**, que se muestran completas **una sola vez**.
4. Llama a la API con la cabecera `X-Api-Key`. Desde el portal consulta su consumo por ruta y sus pagos, rota o revoca sus claves y cambia de plan.

Procesos automáticos

- **La compuerta** valida cada petición contra Redis, aplica los límites y las cuotas, reenvía la petición al origen y registra las métricas en Redis.
- **El trabajador** hace varias tareas en segundo plano:
  - cada 10 segundos pasa las métricas a PostgreSQL;
  - cierra los ciclos de las suscripciones, las renueva, las pone en gracia o las suspende;
  - envía los correos pendientes;
  - verifica los dominios propios.

6. Modelo de negocio

Shapi cobra una **suscripción fija** a cada proveedor, sin comisión. Cada proveedor define además los planes que vende a sus consumidores (**dos niveles de planes**). Shapi cobra a los consumidores por cuenta del proveedor. **Liquidarle ese dinero al proveedor queda fuera del alcance** de esta versión.

Planes de plataforma (datos de siembra)

Plan	Descripción	Precio	Vigencia	APIs	Peticiones por ciclo	Miembros	Dominio propio	Se renueva
Prueba	Publicar una primera API sin costo	Q 0.00	30 días	1	10,000	1	No	**No**: vence a los 30 días (RF-44)
Lanzamiento	Empezar a cobrar por una API existente	Q 199.00	30 días	3	250,000	3	No	Sí
Producto	Proveedores con clientes establecidos	Q 599.00	30 días	10	2,000,000	10	Sí	Sí
Escala mensual	Varias APIs y alto volumen	Q 1,500.00	30 días	Sin límite	10,000,000	Sin límite	Sí	Sí
Escala anual	Alto volumen, con pago anual	Q 15,000.00	365 días	Sin límite	120,000,000	Sin límite	Sí	Sí

La cuota de plataforma se cuenta en **peticiones** y no en llamadas, para que el proveedor no pueda saltársela poniéndoles peso 0 a sus rutas (Glosario).

7. Alcance

Incluido

- Gestión de usuarios con registro, verificación de correo, recuperación de contraseña, sesiones, roles y organizaciones, **tanto para el personal como para los consumidores**.
- Publicación de APIs con especificación OpenAPI, rutas expuestas, subdominios, dominio propio verificado con DNS simulado y secreto de origen.
- Un portal de marca blanca por API, con inicio, documentación generada, consola de pruebas, planes y la cuenta del consumidor.
- La compuerta: validación de claves, límites por minuto, cuotas del consumidor y de la plataforma, caché opcional, reenvío al origen y medición.
- Planes en dos niveles, contratación con pasarela simulada, cambio de plan con prorrateo, renovación automática, periodo de gracia, suspensión y reversión de pagos.
- Paneles de consumo para el proveedor y el consumidor, el panel de administración, la bandeja de casos de soporte (del lado del proveedor y del lado de soporte), el estado de los componentes y la bitácora de acciones sensibles.
- Notificaciones por correo a través de un **servidor de correo simulado** (Mailpit).
- Despliegue reproducible con Docker Compose en un **ambiente productivo simulado** (06 · Arquitectura).

Excluido

- Integración con un procesador de pagos real. Se usa la pasarela simulada que permiten los lineamientos.
- Liquidarle al proveedor lo que cobran sus consumidores.
- Emisión de documentos tributarios electrónicos.
- Dominios y certificados públicos reales. Todo corre en `*.localhost` con la autoridad certificadora interna del borde (ADR-09).
- Un mercado público de APIs: el portal siempre es de marca blanca.
- Ejecución de código subido por los clientes. La plataforma solo enruta tráfico.
- Verificación en dos pasos.
- Que un usuario pertenezca a más de una organización.
- Transferir la propiedad de una organización.
- Que el consumidor cancele la renovación automática.
- Que el proveedor bloquee a un consumidor completo. El proveedor revoca claves, y las suspensiones solo ocurren por falta de pago.
- Bibliotecas propias por lenguaje, alta disponibilidad en varias regiones y aplicación móvil.

8. Restricciones

- El presupuesto es **Q 0.00**: no se compran dominios, servidores ni servicios.
- El stack es el que permiten los lineamientos: .NET 10 (ASP.NET Core), React y PostgreSQL. También se usan Redis, YARP y Caddy.
- Las entregas son el Avance 1 (30 %) el 25 de septiembre, el Avance 2 (50 %) el 9 de octubre, el Avance 3 (80 %) el 31 de octubre, como video (la fecha original era el 23 de octubre), y la entrega final en la primera semana de noviembre de 2026.
- El desarrollo es **dirigido por especificaciones** y lo ejecutan agentes de IA. Estas especificaciones son el contrato que deben respetar.

02 · Glosario

Este glosario define el significado de cada término en todo el proyecto: especificaciones, código, base de datos, interfaz y pruebas. En el código se usan estos mismos nombres en español (por ejemplo `Suscripcion`, `PlanApi` o `consumo_diario`).

Término	Definición
Organización	La empresa registrada en Shapi. Hay dos tipos: `proveedor` (publica APIs) y `plataforma` (una sola, creada en la siembra, a la que pertenecen el administrador y el soporte).
Proveedor	Una organización de tipo `proveedor` o una persona de ella. Es el cliente de Shapi y corresponde al rol "Cliente" del enunciado.
Miembro	Un usuario que pertenece a una organización con un rol: `propietario`, `editor`, `lector`, `administrador` o `soporte`. En esta versión cada usuario pertenece a **una sola** organización.
Personal	El ámbito de identidad de los usuarios de Shapi, es decir, los miembros de cualquier organización. Se autentican en `shapi.localhost`.
Consumidor	El cliente de un proveedor. Es una identidad aparte de *personal*, con correo y contraseña propios, y queda aislada por organización: el mismo correo puede tener cuentas distintas en portales de organizaciones distintas.
API	El servicio que publica un proveedor. Tiene un servidor de origen, un subdominio, rutas, planes y un portal. Equivale al "entorno web" de la categoría del enunciado.
Servidor de origen	El servidor del proveedor que responde las peticiones. Shapi no lo modifica.
Subdominio	El identificador de la API dentro de la plataforma, por ejemplo `envios`. Con él se forman el host del portal (`envios.shapi.localhost`) y el host de la API (`envios.api.shapi.localhost`). Tiene entre 3 y 30 caracteres `[a-z0-9-]`, debe ser único y no puede estar en la lista de reservados.
Dominio base	El dominio de la plataforma. Se configura con `SHAPI_DOMINIO_BASE` y en el entorno simulado vale `shapi.localhost`.
Dominio propio	Un dominio del proveedor que se conecta a la **API** con un registro CNAME, por ejemplo `api.enviosxelaju.localhost` → `envios.api.shapi.localhost`.
DNS simulado	Una tabla interna que reemplaza la consulta DNS real en el entorno simulado (ADR-10).
Ruta	Un par método + patrón que sale de la especificación, por ejemplo `GET /rastreo` o, en una API con parámetros de ruta, `GET /guias/{numero}` (ejemplo ilustrativo). Puede estar *expuesta* u *oculta*.
Portal	El sitio de marca blanca de una API. Tiene inicio, documentación, consola de pruebas, planes, registro y cuenta del consumidor.
Petición	Una solicitud HTTP que llega a la compuerta.
Llamada	La unidad de la **cuota del consumidor**. Cada ruta tiene un *peso en llamadas* (1 o más), y cada petición a esa ruta que llega al origen descuenta ese peso.
Peso en llamadas	Las llamadas que descuenta una petición a una ruta. Por ejemplo, `POST /guias` descuenta 5.

Término	Definición
Límite por minuto	El máximo de **peticiones** por minuto de una suscripción. Lo hay a nivel del plan y, opcionalmente, a nivel de cada ruta. Se aplican los dos.
Cuota del consumidor	Las **llamadas** que incluye el plan de API por ciclo. En la interfaz se muestra como "cuota mensual".
Cuota de plataforma	Las **peticiones** por ciclo que incluye el plan de plataforma, sumando todas las APIs de la organización.
Plan de plataforma	El plan que Shapi vende a los proveedores.
Plan de API	El plan que un proveedor vende a sus consumidores. Puede ser gratuito (precio Q 0.00).
Suscripción	El contrato entre una organización y un plan de plataforma (*suscripción de plataforma*) o entre un consumidor y un plan de API (*suscripción de API*). Los dos tipos usan la misma máquina de estados (09).
Ciclo	El periodo de vigencia de una suscripción, desde `inicio` (incluido) hasta `fin` (excluido), con `fin = inicio + vigencia_dias`. En pantalla se muestra el último día con servicio, `fin − 1 día`. Las cuotas se reinician en cada ciclo.
Periodo de gracia	Los 7 días que siguen a un cobro de renovación rechazado. El servicio sigue funcionando mientras dure.
Suspensión	El estado en que la compuerta responde 403. Puede deberse a una suscripción suspendida (por falta de pago o por el vencimiento del plan Prueba) o a que el administrador suspendió la organización.
Clave	La credencial del consumidor. Hay una de `produccion` y una de `pruebas` por suscripción, con formato `shp_prod_…` y `shp_prueba_…`. Se guarda como hash SHA-256 y se muestra completa una sola vez.
Rotar	Emitir una clave nueva del mismo tipo. La anterior queda en estado `rotada` y sigue funcionando 24 horas. Solo lo hace el consumidor.
Revocar	Invalidar una clave de inmediato. Lo hace el consumidor con las suyas o el proveedor con las de sus consumidores.
Secreto de origen	Un valor que la compuerta envía al origen en la cabecera `X-Shapi-Secreto` para que el proveedor pueda confirmar que la petición pasó por Shapi. Validarlo es opcional.
Compuerta	El proceso del plano de datos (YARP) que valida, limita, reenvía y mide cada petición.
Filtro	Una etapa de la tubería de la compuerta. Deja pasar la petición al siguiente filtro o la rechaza (08).
Plano de control	La API de control (ASP.NET Core en tres capas) y el trabajador. Administran los datos de negocio.
Trabajador	El proceso en segundo plano que consolida el consumo, cierra ciclos, envía correos y verifica dominios.
Consolidación	El paso de las métricas acumuladas en Redis a la tabla `consumo_diario`. Se hace por lotes y es idempotente.
Pasarela simulada	La implementación de `IPasarelaPagos` que autoriza o rechaza pagos según reglas fijas y entrega un token por tarjeta (09).

Término	Definición
Token de pago	El identificador opaco de una tarjeta, emitido por la pasarela. Shapi guarda el token, la marca, los últimos 4 dígitos y el vencimiento, pero **nunca** el número completo ni el CVV.
Prorrateo	El ajuste del monto cuando alguien sube de plan a mitad del ciclo (09).
Bitácora	El registro de acciones sensibles. Solo se le agregan filas, nunca se modifican ni se borran (RF-41).
Caso	Una solicitud de soporte de una organización proveedora hacia Shapi. Se atiende como una conversación (`caso_mensaje`).
Modo demostración	La configuración `SHAPI_MODO_DEMO=true` , que habilita el reloj ajustable y el botón de DNS simulado para mostrar en vivo las renovaciones y la verificación de dominios.

Formatos

- **Moneda:** quetzales, `Q 1,234.56` , almacenados como `numeric(12,2)` .
- **Fechas:** se guardan en UTC (`timestamptz`) y se muestran en la zona `America/Guatemala` , con formato `24 ago 2026` o `24 de agosto de 2026` .
- **Números:** separador de miles `,` y decimal `.` , igual que en los mockups.
- **Idioma:** toda la interfaz está en español y trata al usuario de *usted*, igual que en los mockups.

03 · Requisitos

Los códigos RF-01 a RF-42 **conservan su número** respecto al documento del 11 de septiembre, para que sigan coincidiendo con los mockups. RF-43 a RF-47 son nuevos. Al final hay una tabla con cada cambio.

Cada requisito indica el actor, el criterio de aceptación verificable y las pantallas correspondientes. Las pantallas nuevas están marcadas con ★.

1. Requisitos funcionales

1.1 Gestión de usuarios y acceso

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-01	El sistema permitirá registrar un proveedor con nombre, correo, nombre de la organización y contraseña. Creará la organización, dejará al usuario como **propietario** y pondrá a la organización en el plan **Prueba** sin pedirle tarjeta.	Proveedor	La contraseña tiene al menos 10 caracteres. El correo es único entre el personal. La cuenta queda con el correo sin verificar y la suscripción Prueba queda activa por 30 días.	A1.1
RF-02	El sistema enviará un enlace de verificación al correo del proveedor o del consumidor. El enlace vence a las 24 horas y puede pedirse de nuevo. Mientras no se confirme el correo, **el proveedor no puede publicar APIs y el consumidor no puede contratar planes**.	Proveedor, Consumidor	Si el correo no está verificado, intentar publicar o contratar devuelve el error `correo_no_verificado`. Un enlace ya usado o vencido muestra un mensaje y la opción de reenviarlo.	A1.2, A5.8 ★
RF-03	El sistema permitirá recuperar la contraseña con un enlace de un solo uso que vence a los 60 minutos. **Al usarlo se cierran todas las demás sesiones** de esa cuenta.	Todos	La respuesta es idéntica exista o no el correo, para no revelar qué cuentas existen. El enlace solo sirve una vez. Las sesiones anteriores quedan revocadas.	A1.4a, A1.4b, A5.9 ★, A5.10 ★
RF-04	El sistema autenticará a los usuarios con correo y contraseña y mantendrá una sesión que vence tras un tiempo de inactividad configurable (8 h por defecto) o a los 7 días como máximo. El personal puede cerrar sesión, cambiar su nombre y cambiar su contraseña.	Todos	Tras 5 intentos fallidos, la cuenta se bloquea 15 minutos. La cookie es `HttpOnly`, `Secure` y `SameSite=Lax`. Al cerrar sesión, esa sesión queda revocada en el servidor.	A1.3, A5.7, A8.1 ★
RF-05	El sistema permitirá registrar consumidores desde el portal de una API o **por invitación que el proveedor envía desde su panel**. La invitación vence a los 7 días.	Consumidor, Proveedor	Una cuenta creada por invitación queda con el correo ya verificado. El correo del consumidor es único dentro de su organización.	A5.3, A5.3b, B1.5 ★

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-06	El sistema manejará estos roles: `administrador` y `soporte` en la organización de plataforma; `propietario`, `editor` y `lector` en las organizaciones proveedoras; y **consumidor** como identidad aparte. El propietario puede invitar miembros, cambiar su rol y quitarlos.	Administrador, Propietario	Hay un solo propietario por organización. No se puede invitar un correo que ya pertenece a otra organización (error `correo_en_otra_organizacion`). Aceptar una invitación crea la cuenta y la membresía; si ya existe una cuenta sin organización, conserva esa cuenta y agrega solo la membresía.	A4.2, A8.2 ★
RF-07	El sistema restringirá cada operación según el rol y la organización del usuario, conforme a la matriz de permisos.	Sistema	Toda operación que no esté permitida devuelve 403, y hay pruebas automatizadas por rol.	—

1.2 Publicación y configuración de APIs

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-08	El sistema permitirá registrar una API con nombre, URL del servidor de origen y **subdominio**. Antes de guardar, validará la URL y **probará la conexión** con el origen.	Proveedor (propietario, editor)	La URL es `http` o `https` y **no apunta a direcciones internas** (RNF-10). La prueba de conexión se aprueba si el origen devuelve cualquier respuesta HTTP en menos de 5 segundos. El subdominio cumple el formato, es único y no está reservado (02). Se respeta el límite de APIs del plan (RF-43). La API queda en estado `borrador`.	A3.2
RF-09	El sistema permitirá cargar una especificación OpenAPI 3.0 o 3.1, en JSON o YAML y de hasta 2 MB, y extraerá sus rutas. **Si se vuelve a cargar**, las rutas que ya existían conservan su configuración, las nuevas quedan **ocultas** y las que ya no aparecen se eliminan.	Proveedor (propietario, editor)	Un archivo que no es válido se rechaza, indicando la línea o la sección del error. Se muestran las rutas encontradas.	A3.3
RF-10	El sistema permitirá marcar cada ruta como expuesta u oculta.	Proveedor (propietario, editor)	Solo las rutas expuestas pasan por la compuerta y aparecen en el portal.	A3.4
RF-11	El sistema servirá cada API en dos hosts: `{sub}.api.{dominio_base}` para la API y `{sub}.{dominio_base}` para el portal. Los dos tendrán TLS **emitido y renovado automáticamente por el borde**.	Sistema	Al publicar la API, los dos hosts responden en menos de 10 segundos, sin ningún paso manual.	A3.6

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-12	El sistema permitirá conectar un **dominio propio a la API** si el plan de plataforma lo incluye. La propiedad del dominio se verifica con un registro CNAME que apunta a `{sub}.api.{dominio_base}`. En el entorno simulado, el registro se crea en el **DNS simulado** y el dominio debe terminar en `.localhost`.	Proveedor (propietario, editor)	Solo se verifica el dominio si el CNAME existe y apunta al destino correcto. El certificado se emite con la primera petición. Si el plan no incluye dominio propio, se responde `plan_sin_dominio_propio`.	A3.6
RF-13	El sistema permitirá configurar en cada ruta el **límite por minuto** (en peticiones; si se deja vacío, la ruta no tiene límite propio), la **caché** (en segundos, solo para GET; 0 la desactiva) y el **peso en llamadas** (1 o más).	Proveedor (propietario, editor)	Los cambios llegan a la compuerta en menos de 10 segundos.	A3.5
RF-14	El sistema permitirá publicar y despublicar una API sin eliminar sus datos.	Proveedor (propietario, editor)	Para publicar se necesita el correo verificado, al menos una ruta expuesta y al menos un plan activo. Una API despublicada responde 404 `api_no_encontrada` y su portal muestra "API no disponible".	A3.1
RF-15	El sistema permitirá personalizar el portal **de cada API** con logotipo (PNG o SVG de hasta 512 KB), color principal, nombre del portal y texto de bienvenida.	Proveedor (propietario, editor)	La vista previa muestra los cambios antes de guardarlos. El portal no muestra la marca de Shapi.	A3.7
RF-16	El sistema generará el portal automáticamente: inicio, documentación por ruta (descripción, parámetros y ejemplos sacados de la especificación, más el peso en llamadas) y consola de pruebas. **En la consola, el consumidor pega su clave de pruebas**, que solo se recuerda mientras la pestaña esté abierta.	Sistema, Consumidor	La consola envía la petición real a `{sub}.api.{dominio_base}` y muestra el código y el cuerpo de la respuesta.	A5.0, A5.1, A5.2

1.3 Suscripciones y pagos

El único medio de pago es la tarjeta de crédito o débito, procesada por la **pasarela simulada** (09). Shapi guarda el **token** que entrega la pasarela, la marca, los últimos 4 dígitos y el vencimiento, y **nunca** el número completo ni el CVV.

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-17	El sistema permitirá al administrador crear y editar planes de plataforma con nombre, descripción, precio, vigencia en días, máximo de APIs, máximo de miembros, cuota de peticiones y si incluyen dominio propio.	Administrador	Un plan con suscripciones no se elimina: se desactiva. Los cambios de precio se aplican a partir de la siguiente renovación.	A6.1

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-18	El sistema permitirá al proveedor crear y editar planes de API con nombre, descripción, precio, vigencia, cuota de llamadas por ciclo y límite de peticiones por minuto, y marcarlos como gratuitos.	Proveedor (propietario, editor)	Un plan gratuito tiene precio Q 0.00. Los cambios de cuota y de límite se aplican de inmediato a las suscripciones vigentes; los de precio, a partir de la siguiente renovación. Los planes con suscripciones se desactivan en vez de eliminarse.	A4.1
RF-19	El sistema mostrará los planes disponibles al proveedor y al consumidor antes de contratar.	Todos	Solo se muestran los planes activos.	A0, A2.1, A5.4
RF-20	El sistema permitirá contratar un plan con tarjeta y activará la suscripción **en el momento en que la pasarela autorice el cobro**. Los planes gratuitos se activan sin pedir tarjeta. Si el cobro se rechaza, no se crea la suscripción y la suscripción vigente no cambia.	Proveedor (propietario), Consumidor	El pago queda registrado como `autorizado` o `rechazado`. Al activarse una suscripción de API se emiten sus claves (RF-26).	A2.2, A2.3, A2.4, A5.6, A5.4b
RF-21	El sistema registrará el historial de pagos de cada organización y de cada consumidor.	Proveedor (propietario, lector), Consumidor	Cada pago muestra fecha, concepto, periodo, monto, medio de pago y estado.	B1.3, B2.2
RF-22	El sistema renovará automáticamente las suscripciones al cerrar cada ciclo, cobrando al medio de pago registrado.	Sistema	La renovación ocurre en el primer minuto después de `fin`. Si se autoriza, empieza un ciclo nuevo y la cuota se reinicia. Si se rechaza, se aplica RF-23.	B1.4, B2.3
RF-23	El sistema aplicará un **periodo de gracia de 7 días** cuando se rechace el cobro de una renovación y **suspenderá** la suscripción si no se paga en ese plazo. Mientras dure la gracia, el servicio sigue funcionando. Si se suspende la plataforma de una organización, **todas sus APIs responden 403**; si se suspende la suscripción de un consumidor, **sus claves responden 403**. Un cobro autorizado reactiva la suscripción con un ciclo nuevo desde ese día.	Sistema, Proveedor, Consumidor	Las pantallas muestran los días que quedan de gracia. La reactivación llega a la compuerta en menos de 10 segundos.	B1.4, B2.3, A6.2
RF-24	El sistema permitirá al administrador **revisar los pagos de plataforma y revertir** un cobro autorizado.	Administrador	Un pago revertido queda en estado `revertido`. Si ese pago cubría el ciclo vigente, la suscripción entra en gracia. La acción queda en la bitácora.	A6.3
RF-25	El sistema permitirá cambiar de plan. **Subir** de plan se cobra prorrateado y se aplica de inmediato. **Bajar** de plan se aplica en la siguiente renovación, sin reembolso. **No se puede bajar** a un plan si la organización excede sus límites (por ejemplo, si tiene más APIs publicadas de las que el plan permite).	Proveedor (propietario), Consumidor	El monto del prorrateo sigue la fórmula de 09 §5. Un cambio a un plan más barato queda programado en `plan_siguiente_id` y la pantalla lo indica.	A2.5, B2.7 ★

1.4 Compuerta de tráfico

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-26	El sistema emitirá una clave de producción y una de pruebas al activarse una suscripción de API y **las mostrará completas una sola vez**.	Sistema	En la base de datos solo se guardan el prefijo, los últimos 4 caracteres y el hash SHA-256. Después de mostrarlas, solo se ven enmascaradas (`shp_prod_••••7c2e`).	A5.4b, B2.3
RF-27	El sistema permitirá **al consumidor** rotar una de sus claves. La clave nueva se muestra una sola vez y la anterior sigue funcionando 24 horas.	Consumidor	Una clave ya rotada no se puede volver a rotar. Durante esas 24 horas coexisten, como máximo, dos claves del mismo tipo.	B2.3, B2.4 ★, B2.5 ★
RF-28	El sistema permitirá revocar una clave, al **consumidor** si es suya y al **proveedor** si es de uno de sus consumidores. La revocación se hace efectiva en **menos de 10 segundos**. Después de revocar una clave, el consumidor puede emitir una nueva del mismo tipo.	Consumidor, Proveedor (propietario, editor)	Una petición con una clave revocada recibe 401 `clave_invalida`. Las revocaciones que hace el proveedor quedan en la bitácora.	A4.3, A4.3b, B2.6 ★
RF-29	El sistema validará en cada petición que la API esté publicada, la clave, el estado de la organización, el estado de la suscripción y que la ruta esté expuesta. Rechazará con **404, 401 o 403** según corresponda.	Sistema	Los códigos y el formato del error son los de 08 §4.	—
RF-30	El sistema rechazará con **429** las peticiones que superen el límite por minuto (del plan o de la ruta), las que agoten la cuota del consumidor y las que agoten la cuota de plataforma del proveedor.	Sistema	Cada caso tiene su propio código de error y la cabecera `Retry-After`. La cuota nunca se excede, gracias a la reserva atómica (08 §3).	—
RF-31	El sistema reenviará al origen solo las peticiones que pasen todos los filtros. Antes de reenviarlas quitará `X-Api-Key` y agregará `X-Shapi-Consumidor`, `X-Shapi-Entorno` y, si existe, `X-Shapi-Secreto`.	Sistema	El origen nunca recibe la clave del consumidor.	—
RF-32	El sistema devolverá al consumidor cabeceras con el plan vigente, el límite por minuto y la cuota restante.	Sistema	Las cabeceras son las de 08 §5.	—
RF-33	El sistema registrará de cada petición la API, la ruta, la suscripción, el entorno, el código de respuesta, la latencia total, la latencia de la compuerta y los bytes de entrada y de salida.	Sistema	Esto se hace **después** de la respuesta y sin tocar PostgreSQL (RNF-02).	—
RF-34	El sistema consolidará cada 10 segundos las métricas acumuladas en Redis en la tabla `consumo_diario`, sin perder datos y sin contarlos dos veces.	Sistema (trabajador)	Si se interrumpe la consolidación en cualquier punto, al reiniciarse no pierde ni duplica datos (08 §7).	—

1.5 Consulta, administración y soporte

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-35	El sistema mostrará al proveedor, por cada API y periodo: peticiones, llamadas descontadas, **latencia total p95 y latencia de la compuerta p95** (sacadas de histogramas), errores por código (401/403/429 de la compuerta y 4xx/5xx/fallas de conexión del origen), y **bytes transferidos**.	Proveedor	Las cifras salen de `consumo_diario`. El p95 se calcula por interpolación dentro de cada rango del histograma (08 §7).	B1.1
RF-36	El sistema mostrará al proveedor el consumo del ciclo y la facturación de cada consumidor.	Proveedor	El consumo es igual a la suma de llamadas del ciclo vigente de cada suscripción.	B1.2
RF-37	El sistema mostrará al consumidor su consumo del ciclo, desglosado por ruta: peticiones, peso y llamadas descontadas.	Consumidor	Los totales coinciden con la cuota restante que informan las cabeceras, con un desfase máximo de 10 segundos.	B2.1
RF-38	El sistema permitirá al administrador listar organizaciones y suspenderlas o reactivarlas por motivos administrativos.	Administrador	Una suspensión administrativa hace que la compuerta responda 403 en menos de 10 segundos. Queda en la bitácora.	A6.2, A6.2b
RF-39	El sistema mostrará al administrador y al soporte el estado de cada componente y la latencia p95 que añade la compuerta.	Administrador, Soporte	Los estados son `en_servicio`, `degradado` o `fuera_de_servicio`, y se calculan con verificaciones de salud cada 30 segundos (06 §8).	B3.1
RF-40	El sistema permitirá **al proveedor abrir casos de soporte y conversar en ellos**, y **al soporte y al administrador** registrar casos a nombre de una organización, responder, asignarse casos y cerrarlos, con acceso de **solo lectura** a los datos de la organización.	Proveedor, Soporte, Administrador	Cada respuesta notifica por correo a la otra parte. Un caso cerrado no admite más mensajes.	A7.1 ★, A7.2 ★, A6.4
RF-41	El sistema registrará en una bitácora las acciones sensibles, indicando actor, organización, acción, objetivo, fecha e IP.	Sistema	La lista de acciones está en 10 §7. La bitácora no admite UPDATE ni DELETE.	B3.2
RF-42	El sistema permitirá al administrador crear, desactivar y reactivar cuentas de administración y de soporte. Estas cuentas no tienen registro público.	Administrador	La cuenta nueva recibe un enlace para definir su contraseña, que vence a los 7 días. Un administrador no puede desactivar su propia cuenta.	A6.5
RF-43	El sistema aplicará los **límites del plan de plataforma**: máximo de APIs registradas, máximo de miembros (contando las invitaciones pendientes), dominio propio y cuota de peticiones. Avisará en el panel cuando se llegue al 80 % y al 100 % de la cuota.	Sistema	Pasar un límite devuelve `limite_del_plan` con el nombre del límite. La compuerta aplica la cuota de peticiones (RF-30).	A3.1, A4.2

Código	Requisito	Actor	Criterio de aceptación	Pantallas
RF-44	El plan **Prueba** vence a los 30 días y no se renueva. Si en ese plazo la organización no contrata un plan de pago, su suscripción pasa a gracia y después a suspensión, como en RF-23.	Sistema	El panel avisa 7 días antes del vencimiento.	B1.4
RF-45	La **clave de pruebas** llega al mismo origen con `X-Shapi-Entorno: pruebas`, **no descuenta cuota ni se factura**, y tiene un límite fijo de 10 peticiones por minuto y 1,000 por día.	Sistema	Las métricas se guardan con `entorno = pruebas`.	A5.2
RF-46	El sistema enviará correos de verificación, recuperación, invitación (a miembros, a consumidores y a cuentas de plataforma), pago rechazado, entrada en gracia, suspensión, aviso de vencimiento de la Prueba y respuesta a un caso.	Sistema (trabajador)	Los correos pasan por la tabla `correo_saliente` y se reintentan hasta 5 veces. En el entorno simulado llegan a Mailpit.	—
RF-47	El sistema generará para cada API un **secreto de origen**, que se muestra una sola vez y puede regenerarse, y lo enviará en `X-Shapi-Secreto` en cada petición reenviada.	Proveedor (propietario, editor)	Se guarda cifrado con ASP.NET Data Protection. Al regenerarlo, el anterior deja de enviarse en menos de 10 segundos.	A3.6

2. Requisitos no funcionales

Están ordenados según ISO/IEC 25010 y cada uno tiene un criterio que se puede medir, salvo RNF-06 y RNF-11, que son objetivos de diseño y dicen qué los respalda.

Código	Característica	Requisito y criterio de verificación
RNF-01	Eficiencia	La compuerta no añadirá más de **15 ms en el percentil 95** al tiempo de respuesta del origen. Se mide con una prueba de carga contra un origen de demostración.
RNF-02	Eficiencia	Validar una petición **no consultará PostgreSQL**; todo se resuelve contra Redis. Se verifica con una prueba que apaga PostgreSQL.
RNF-03	Eficiencia	El sistema soportará al menos **200 peticiones por segundo** sostenidas durante 5 minutos, en el equipo de despliegue, con menos del 1 % de errores de la compuerta.
RNF-04	Fiabilidad	La compuerta seguirá enrutando aunque la API de control, el trabajador o PostgreSQL estén fuera de servicio, siempre que Redis esté disponible.
RNF-05	Fiabilidad	Una caída del trabajador no hará perder datos de consumo ni de facturación. Redis se configura con persistencia AOF (`appendfsync everysec`) y la consolidación es idempotente. Si Redis pierde sus datos, la caché se reconstruye desde PostgreSQL.

Código	Característica	Requisito y criterio de verificación
RNF-06	Fiabilidad	La disponibilidad mensual objetivo del enrutamiento es del **99.5 %** en un despliegue real. Es un **objetivo de diseño**: el ambiente productivo simulado no corre de forma continua, así que no se mide. Lo respaldan tres mecanismos: el reinicio automático y las verificaciones de salud de los contenedores (06 §7); que la compuerta siga enrutando aunque fallen la API de control, el trabajador o PostgreSQL (RNF-04); y el estado de los componentes de B3.1 (06 §8).
RNF-07	Seguridad	Las contraseñas se guardan con **PBKDF2** (el hasher de ASP.NET Core Identity, v3). Las claves de API se guardan con **hash SHA-256** y se muestran una sola vez. Los tokens de correo y los identificadores de sesión se guardan con hash. El secreto de origen se guarda **cifrado** con Data Protection. Nunca se guardan datos completos de tarjetas.
RNF-08	Seguridad	Ninguna consulta devolverá datos de una organización distinta a la del solicitante. Se aplica con un filtro global de EF Core por organización y se verifica con pruebas automatizadas de aislamiento.
RNF-09	Seguridad	Todo el tráfico se servirá por **HTTPS**, con certificados que el borde emite y renueva automáticamente antes de su vencimiento (en el entorno simulado, con la autoridad certificadora interna de Caddy). HTTP redirige a HTTPS.
RNF-10	Seguridad	La plataforma **no ejecutará código de los clientes**; solo enruta tráfico. Las URL de origen no pueden resolver a direcciones de loopback, privadas, link-local ni de la red interna de Docker. Esto se valida **al guardar la URL y al abrir cada conexión**, como protección contra SSRF.
RNF-11	Usabilidad	Publicar una API, desde el registro hasta la primera respuesta válida, tomará **menos de 5 minutos**. Es un **objetivo de diseño** y no se mide. Lo respalda un flujo sin intervención del administrador ni del soporte de Shapi y sin esperas de aprobación (05, CU-01, CU-05, CU-09, CU-11, CU-12 y CU-14): el proveedor y el consumidor verifican su correo con un enlace, la conexión con el origen se prueba al registrar la API, publicar no necesita aprobación, los hosts responden en menos de 10 segundos (RF-11), un plan gratuito se activa sin pedir tarjeta (RF-20) y las claves se entregan al activarse la suscripción (RF-26).
RNF-12	Usabilidad	Las interfaces estarán en español y funcionarán en la versión actual de Chrome, Edge y Firefox de escritorio, desde 1280 px de ancho.
RNF-13	Mantenibilidad	Agregar una regla de validación a la compuerta consistirá en **agregar un filtro** a la tubería sin modificar los demás. La cuota de plataforma (RF-30) sirve de ejemplo.
RNF-14	Portabilidad	Todo el sistema se levantará en cualquier equipo con **un solo comando** (`docker compose up`), con los datos de siembra de los mockups.
RNF-15	Mantenibilidad	Las reglas de negocio del dominio, cada filtro de la compuerta y el aislamiento entre organizaciones tendrán pruebas automatizadas que se ejecutan en la integración continua. No se integra a `main` nada que tenga pruebas fallidas.

3. Trazabilidad con los lineamientos

Lineamiento	Requisitos
Registro, validación de correo, recuperación de contraseña	RF-01, RF-02, RF-03, RF-05
Autenticación segura y manejo de sesiones	RF-04, RNF-07
Roles (Administrador y Cliente como mínimo; Soporte es opcional)	RF-06, RF-07, RF-42
Servicios con nombre, descripción, precio y vigencia	RF-17, RF-18
Visualización de planes, contratación, historial de pagos y renovación	RF-19, RF-20, RF-21, RF-22, RF-23, RF-25
Crear entornos web	RF-08 a RF-11, RF-14
Gestionar configuraciones	RF-12, RF-13, RF-15, RF-47
Monitorear consumo de recursos	RF-35, RF-36, RF-37, RF-39
Despliegue en ambientes productivos	RNF-09, RNF-14, 06 §7

4. Cambios respecto al documento del 11 de septiembre

Requisito	Cambio	Decisión
RF-02, RF-03	Se amplían a los consumidores; la recuperación cierra las demás sesiones	ADR-04, ADR-06
RF-04	Se agregan bloqueo tras intentos fallidos, cierre de sesión y perfil	ADR-06
RF-05	Se agrega que el proveedor envía la invitación desde su panel	ADR-29
RF-06	Un solo propietario por organización y una sola organización por usuario	ADR-05
RF-08	El subdominio lo elige el proveedor; se agregan la protección contra SSRF y la prueba de conexión	ADR-07, ADR-11
RF-11	Hosts separados para el portal y la API; certificados emitidos por el borde	ADR-08, ADR-09
RF-12	El dominio propio es solo para la API; se verifica con DNS simulado	ADR-10
RF-13	El límite por minuto se cuenta en peticiones; el "peso en llamadas" reemplaza a la "unidad de medición"	ADR-18
RF-15	La personalización es por API	ADR-07
RF-24	Se elimina "rechazar un pago": los rechazos los decide la pasarela	ADR-12
RF-25	Se definen las reglas para subir y bajar de plan	ADR-17

Requisito	Cambio	Decisión
RF-26, RF-27, RF-28	Las claves se guardan con hash y se muestran una vez; rota el consumidor; revocan el consumidor y el proveedor; soporte no toca claves	ADR-01, ADR-02
RF-29, RF-30	Se agregan el 404 por API despublicada y el 429 por cuota de plataforma	ADR-20
RF-35	Se agregan histogramas, bytes y errores por código	ADR-23
RF-40	El proveedor abre y conversa en sus casos	ADR-29
RF-43 a RF-47	Requisitos nuevos	ADR-16, ADR-19, ADR-24, ADR-27, ADR-11
RNF-04, RNF-05, RNF-07, RNF-09, RNF-10	Se precisan	ADR-01, ADR-09, ADR-11, ADR-22, ADR-27
RNF-06	Queda como objetivo de diseño para un despliegue real: no se mide en el ambiente productivo simulado	Decisión de Jordin del 27 sep (auditoría del 25 sep, H-113)
RNF-11	Queda como objetivo de diseño: no se mide	Decisión de Jordin del 27 sep (auditoría del 25 sep, H-113)
RNF-15	Requisito nuevo	ADR-31

04 · Roles y permisos

Esta matriz define el RF-07. En el backend se implementa con *policies* de ASP.NET Core, una por permiso, y la regla es **denegar todo por defecto**. El frontend oculta las opciones no permitidas, pero **la autorización la decide siempre el backend**.

1. Ámbitos de identidad

Ámbito	Quiénes	Dónde se autentican	Cookie
`personal`	Miembros de cualquier organización: administrador, soporte, propietario, editor y lector	`https://shapi.localhost`	`shapi_sesion` (host `shapi.localhost`)
`consumidor`	Consumidores de una organización proveedora	`https://{sub}.shapi.localhost`, el portal de cada API	`portal_sesion` (host del portal; no se comparte entre portales)

Una sesión de un ámbito **nunca** da acceso a las rutas del otro. Un consumidor que entra a otro portal de la **misma** organización usa las mismas credenciales, pero inicia sesión otra vez, porque la cookie pertenece a cada host.

2. Roles

Rol	Organización	Descripción
`administrador`	Plataforma	Opera Shapi.
`soporte`	Plataforma	Atiende casos. Ve los datos de las organizaciones en solo lectura.
`propietario`	Proveedor	Hay uno por organización y lo tiene quien la registró. Puede hacer todo en su organización.
`editor`	Proveedor	Configura APIs, planes y el portal. No toca el cobro ni los miembros.
`lector`	Proveedor	Consulta todo lo de su organización, incluidos los pagos, sin modificar nada.
consumidor	— (identidad aparte)	Administra su cuenta, sus suscripciones y sus claves en un portal.

3. Matriz de permisos

Leyenda: ✅ permitido · 👁 solo lectura · — no permitido.

3.1 Panel del proveedor

Permiso	Propietario	Editor	Lector	Admin	Soporte
Ver APIs, rutas, planes, portal y dominios	✅	✅	👁	—	👁 (desde el caso)
Registrar, configurar, publicar y despublicar APIs	✅	✅	—	—	—
Cargar la especificación y exponer u ocultar rutas	✅	✅	—	—	—
Configurar rutas (límite, caché y peso)	✅	✅	—	—	—
Personalizar el portal	✅	✅	—	—	—
Conectar un dominio propio	✅	✅	—	—	—
Ver y regenerar el secreto de origen	✅	✅	—	—	—
Crear, editar y desactivar planes de API	✅	✅	—	—	—
Ver las claves de los consumidores (enmascaradas)	✅	✅	👁	—	—
Revocar claves de los consumidores	✅	✅	—	—	—
Rotar claves de los consumidores	—	—	—	—	—
Ver consumo y consumidores	✅	✅	👁	—	👁 (desde el caso)
Invitar consumidores	✅	✅	—	—	—
Invitar y quitar miembros, y cambiar su rol	✅	—	—	—	—
Contratar o cambiar el plan de plataforma y registrar la tarjeta	✅	—	—	—	—
Ver la suscripción de plataforma y el historial de pagos	✅	—	👁	—	👁 (resumen en el caso)
Abrir casos de soporte y responder en ellos	✅	✅	✅	—	—
Editar el perfil propio y cerrar sesión	✅	✅	✅	✅	✅

3.2 Panel de administración

Permiso	Admin	Soporte
Crear, editar y desactivar planes de plataforma	✅	—
Listar organizaciones	✅	👁
Suspender o reactivar organizaciones	✅	—
Ver los pagos de plataforma	✅	—
Revertir pagos	✅	—
Ver casos	✅	✅
Registrar casos a nombre de una organización, responder, asignarse y cerrar casos	✅	✅
Ver los datos de la organización desde un caso (solo lectura)	✅	✅
Ver el estado de los componentes	✅	✅
Ver la bitácora	✅	✅
Crear, desactivar y reactivar cuentas de administración y de soporte	✅	—

3.3 Portal del consumidor

Permiso	Visitante sin sesión	Consumidor
Ver el inicio, la documentación y los planes	✅	✅
Usar la consola de pruebas (con su clave pegada)	✅	✅
Registrarse, iniciar sesión y recuperar la contraseña	✅	—
Contratar o cambiar de plan (con el correo verificado)	—	✅
Ver su suscripción, sus claves enmascaradas, su consumo y sus pagos	—	✅
Rotar y **revocar** sus propias claves, y emitir una nueva si una está revocada	—	✅

4. Reglas adicionales

1. **Aislamiento entre organizaciones (RNF-08).** Toda entidad que pertenece a una organización se filtra por el `organizacion_id` de la sesión. Si el recurso pedido pertenece a otra organización, se responde **404**, no 403, para no revelar que existe.
2. **El soporte nunca modifica** datos de las organizaciones. Solo puede escribir en `caso` y `caso_mensaje`.

3. **Operaciones sobre uno mismo:** el propietario no puede quitarse ni cambiarse el rol, y un administrador no puede desactivar su propia cuenta.
4. **Organización suspendida:** mientras está suspendida, su personal puede entrar al panel para pagar, consultar datos y abrir casos, pero **no puede publicar APIs nuevas**.
5. **Consumidor con suscripción suspendida:** puede entrar al portal y pagar con otra tarjeta. Sus claves responden 403 hasta que pague.
6. **Se deniega por defecto.** Todo endpoint de la API de control exige una sesión, salvo los que se declaran públicos de forma explícita (`AllowAnonymous`). Solo son públicos los que la especificación declara así:
   - los de `/api/auth` que reciben credenciales o enlaces: `registro`, `verificar-correo`, `reenviar-verificacion`, `entrar`, `recuperar`, `restablecer` (RF-03) y `definir-contrasena` (RF-42);
   - `/api/auth/salir` (10 §1);
   - `GET /api/invitaciones/{token}` y `POST /api/invitaciones/{token}/aceptar` (RF-06; enlaces con token de un solo uso);
   - los del portal para visitantes sin sesión (§3.3);
   - `/salud` y `/interno/tls/autorizar` (06);
   - `/openapi`, solo en *Development*.

   Sin sesión, un endpoint protegido responde 401.

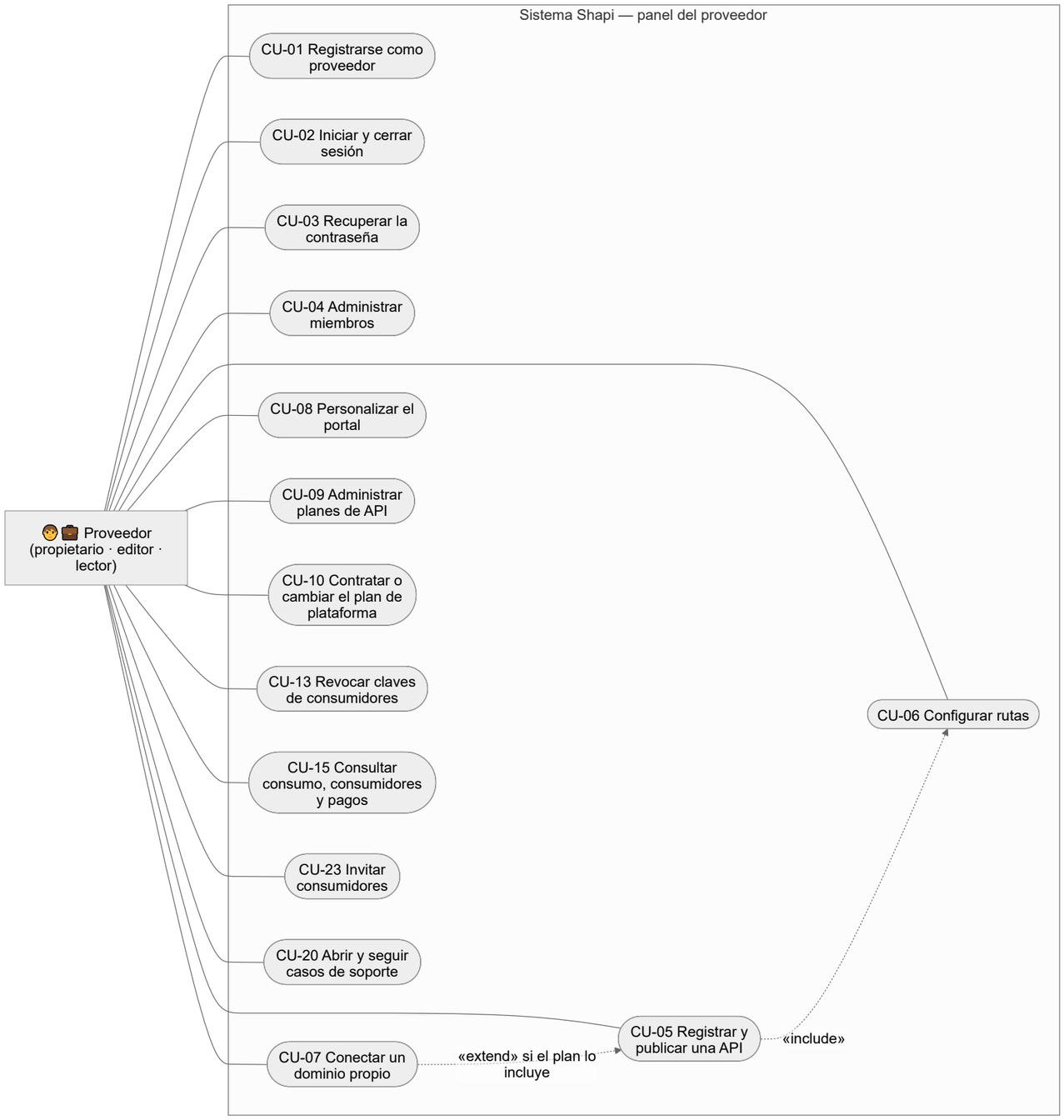
05 · Casos de uso

1. Diagramas de casos de uso

Hay un diagrama por grupo de actores para que se pueda leer. El caso compartido de autenticación (CU-02 y CU-03) aparece en los tres.

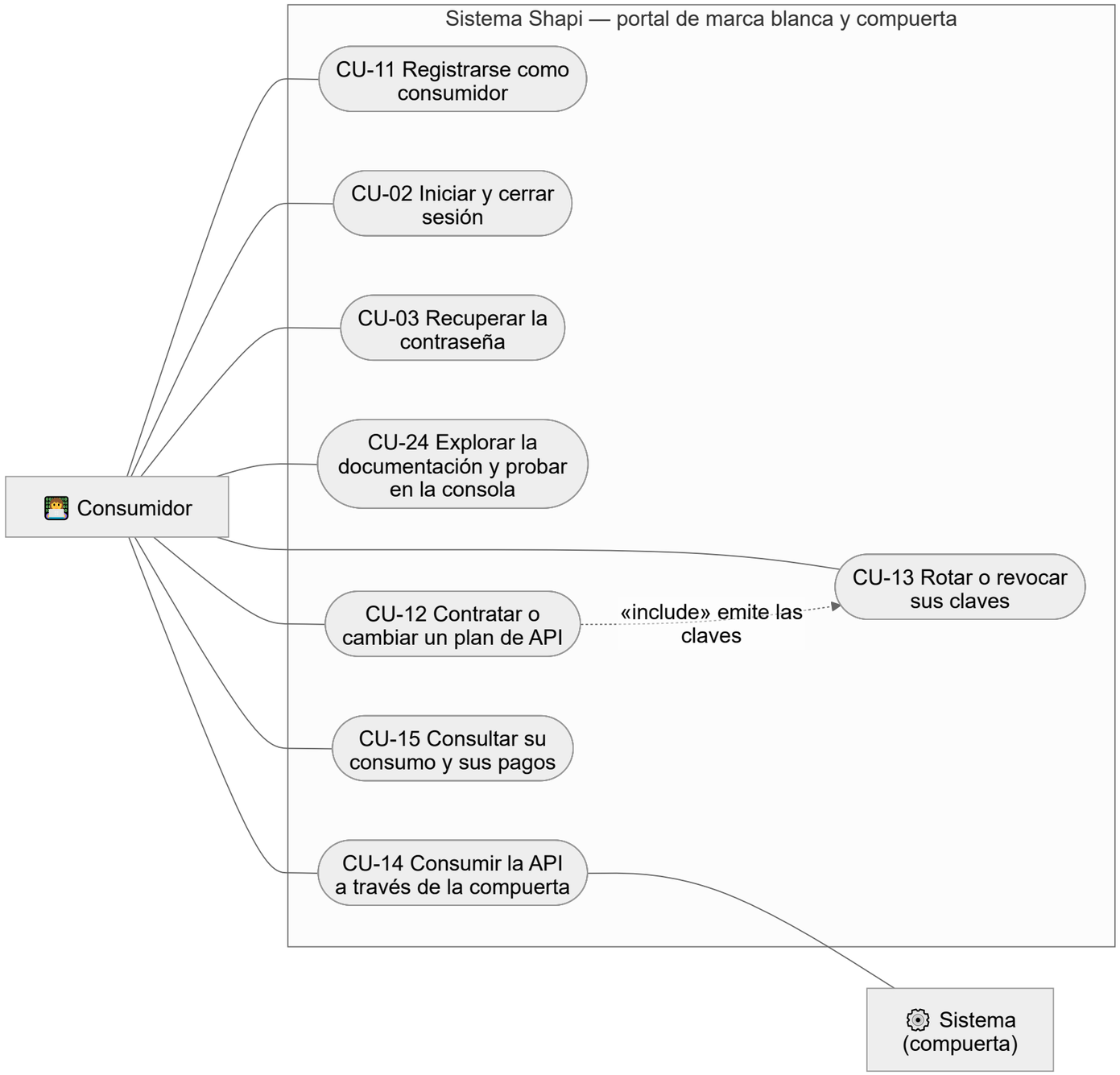
1.1 Proveedor

Diagrama 1 · Vista general



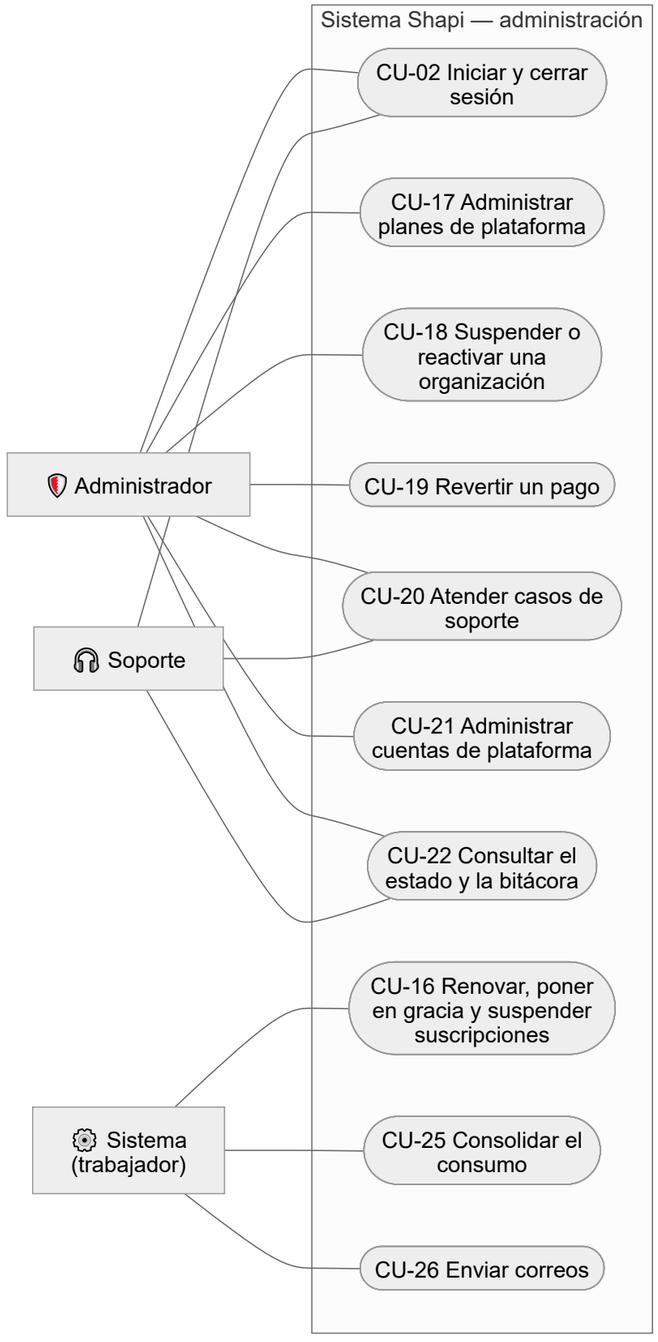
1.2 Consumidor

Diagrama 2 · Vista general



1.3 Administrador, soporte y procesos automáticos

Diagrama 3 · Vista general



2. Especificaciones

Formato: **Actor**, **Precondiciones**, **Flujo principal**, **Flujos alternos**, **Postcondiciones**, **Requisitos** y **Pantallas**.

CU-01 Registrarse como proveedor

- **Actor:** visitante (futuro propietario).
- **Precondiciones:** ninguna.
- **Flujo principal:**
  1. El visitante abre `/registro` y escribe su nombre, correo, nombre de la organización y contraseña.
  2. El sistema valida los datos, crea el usuario, la organización y la membresía de `propietario`, y la suscripción al plan Prueba (activa por 30 días).
  3. El sistema pone en la cola el correo de verificación y muestra el aviso A1.2.
  4. El visitante abre el enlace. El sistema marca el correo como verificado e inicia la sesión.
- **Flujos alternos:**
  - **2a.** El correo ya existe: se muestra "Ya existe una cuenta con ese correo", con enlaces a entrar y a recuperar la contraseña.
  - **4a.** El enlace venció o ya se usó: se ofrece reenviarlo.
- **Postcondiciones:** existe una organización en el plan Prueba, con el correo sin verificar hasta que se completa el paso 4.
- **Requisitos:** RF-01, RF-02 · **Pantallas:** A1.1, A1.2.

CU-02 Iniciar y cerrar sesión

- **Actor:** personal o consumidor.
- **Precondiciones:** la cuenta existe y está activa.
- **Flujo principal:**
  1. El actor escribe su correo y su contraseña.
  2. El sistema los verifica, crea una sesión y envía la cookie de su ámbito.
  3. El sistema lo enruta: el administrador y el soporte a `/admin`, el proveedor a `/panel/apis` y el consumidor a `/cuenta/suscripcion` o, si no tiene suscripción, a `/planes` (el destino según el rol de 10 §1).
  4. Al cerrar sesión, la sesión queda revocada.
- **Flujos alternos:**
  - **2a.** Las credenciales no son válidas: se muestra un mensaje genérico. Al quinto intento, la cuenta se bloquea 15 minutos.
  - **2b.** La cuenta está desactivada: se muestra "Cuenta desactivada".
- **Requisitos:** RF-04 · **Pantallas:** A1.3, A5.7, A8.1.

CU-03 Recuperar la contraseña

- **Actor:** personal o consumidor.

- **Flujo principal:**
  1. El actor escribe su correo.
  2. El sistema responde siempre "Si el correo existe, le enviamos un enlace" y, si la cuenta existe, pone en la cola un enlace que vence a los 60 minutos.
  3. El actor abre el enlace y escribe su contraseña nueva.
  4. El sistema la guarda, marca el enlace como usado, revoca todas las sesiones anteriores e inicia una sesión nueva.
- **Flujos alternos:**
  - **3a.** El enlace venció o ya se usó: se ofrece pedir otro.
- **Requisitos:** RF-03 · **Pantallas:** A1.4a, A1.4b, A5.9, A5.10.

CU-04 Administrar miembros

- **Actor:** propietario.
- **Flujo principal:**
  1. El propietario escribe el correo y el rol (editor o lector) y envía la invitación.
  2. El sistema valida el límite de miembros (RF-43), crea el token de invitación (vence a los 7 días) y pone en la cola el correo.
  3. La persona invitada abre el enlace, escribe su nombre y su contraseña, y queda como miembro. Si ya tiene una cuenta sin organización, se agrega la membresía y conserva sus datos de acceso.
  4. El propietario puede cambiar el rol de un miembro o quitarlo, con confirmación.
- **Flujos alternos:**
  - **2a.** El correo ya pertenece a otra organización: error `correo_en_otra_organizacion`.
  - **2b.** Se llegó al límite del plan: error `limite_del_plan`.
- **Requisitos:** RF-06, RF-43 · **Pantallas:** A4.2, A8.2.

CU-05 Registrar y publicar una API

- **Actor:** propietario o editor.
- **Precondiciones:** el correo está verificado para publicar (para registrar no hace falta) y no se llegó al límite de APIs.
- **Flujo principal:**
  1. El actor escribe el nombre, la URL de origen y el subdominio.
  2. El sistema valida el formato, la disponibilidad del subdominio y que la URL no apunte a direcciones internas, y **prueba la conexión** con el origen.
  3. El sistema guarda la API en estado `borrador` y genera el secreto de origen (se muestra una vez).
  4. El actor carga la especificación. El sistema extrae las rutas y todas quedan ocultas.
  5. El actor expone rutas, las configura (CU-06), crea al menos un plan (CU-09) y pulsa "Publicar".
  6. El sistema publica la configuración en Redis. El portal y la API empiezan a responder en sus hosts.
- **Flujos alternos:**
  - **2a.** El origen no responde: "No pudimos conectar con su servidor", con el detalle del error. No se guarda nada.

    - **2b.** El subdominio está ocupado o reservado: se piden alternativas.
    - **4a.** La especificación no es válida: se indica el error.
    - **5a.** Falta verificar el correo, no hay ninguna ruta expuesta o no hay ningún plan activo: se indica qué falta.
- **Requisitos:** RF-08 a RF-11, RF-14, RF-43, RF-47 · **Pantallas:** A3.1 a A3.4, A3.6.

CU-06 Configurar rutas

- **Actor:** propietario o editor.
- **Flujo principal:** el actor define por ruta el límite por minuto, la caché y el peso en llamadas y guarda. El sistema publica los cambios en Redis en menos de 10 segundos.
- **Flujos alternos:** si se configura caché en una ruta que no es GET, el campo se deshabilita.
- **Requisitos:** RF-10, RF-13 · **Pantallas:** A3.4, A3.5.

CU-07 Conectar un dominio propio

- **Actor:** propietario o editor.
- **Precondiciones:** el plan incluye dominio propio.
- **Flujo principal:**
    1. El actor escribe el dominio.
    2. El sistema muestra el registro CNAME que hay que crear, con destino `{sub}.api.shapi.localhost`.
    3. En el entorno simulado, el actor pulsa "Simular la creación del registro" y el sistema lo inserta en el DNS simulado.
    4. El actor pulsa "Verificar registro DNS". El sistema consulta el resolutor configurado y, si el registro coincide, marca el dominio como `verificado`.
    5. Con la primera petición al dominio, el borde pide autorización a la API de control y emite el certificado.
- **Flujos alternos:**
    - **4a.** El registro no existe o apunta a otro destino: el dominio queda `pendiente`, con el motivo. Si en 72 horas no se verifica, pasa a `fallido`.
- **Requisitos:** RF-12 · **Pantallas:** A3.6.

CU-08 Personalizar el portal

- **Actor:** propietario o editor.
- **Flujo principal:** el actor sube el logotipo y elige el color, el nombre y el texto de bienvenida. La vista previa se actualiza en vivo. Al guardar, el portal publicado muestra los cambios.
- **Requisitos:** RF-15, RF-16 · **Pantallas:** A3.7.

CU-09 Administrar planes de API

- **Actor:** propietario o editor.
- **Flujo principal:** el actor crea o edita un plan con nombre, descripción, precio (o lo marca como gratuito), vigencia, cuota de llamadas y límite por minuto. El sistema lo publica en el portal.
- **Flujos alternos:**

    - Si el plan tiene suscripciones, "eliminar" lo desactiva.
    - Los cambios de cuota y de límite se aplican de inmediato; los de precio, en la siguiente renovación.
- **Requisitos:** RF-18 · **Pantallas:** A4.1.

CU-10 Contratar o cambiar el plan de plataforma

- **Actor:** propietario.
- **Flujo principal:**
    1. El actor elige un plan en A2.1.
    2. Si viene del plan Prueba o de un plan más barato, el sistema calcula el monto a pagar hoy (el precio completo o el prorrateo).
    3. El actor escribe los datos de la tarjeta o usa la que tiene registrada.
    4. La pasarela simulada autoriza el cobro. El sistema registra el pago y activa el plan.
- **Flujos alternos:**
    - **4a.** La pasarela rechaza el cobro: se muestra A2.4 y el plan vigente no cambia.
    - **2a.** El plan elegido es más barato: el cambio se programa para la siguiente renovación, sin cobro. Si la organización excede los límites del plan nuevo, se rechaza con `excede_limites_del_plan`.
- **Requisitos:** RF-19, RF-20, RF-25 · **Pantallas:** A2.1 a A2.5.

CU-11 Registrarse como consumidor

- **Actor:** visitante del portal.
- **Flujo principal:**
    1. El visitante escribe su nombre, correo, nombre de la empresa y contraseña.
    2. El sistema crea el consumidor dentro de la organización de ese portal y pone en la cola el correo de verificación.
    3. El visitante confirma su correo.
- **Flujos alternos:**
    - **1a.** Llega por invitación: el correo ya viene escrito y la cuenta queda verificada.
    - **2a.** El correo ya existe en esa organización: se ofrecen entrar y recuperar la contraseña.
- **Requisitos:** RF-05, RF-02 · **Pantallas:** A5.3, A5.3b, A5.8.

CU-12 Contratar o cambiar un plan de API

- **Actor:** consumidor con el correo verificado.
- **Flujo principal:**
    1. El consumidor elige un plan en A5.4.
    2. Si el plan es de pago, escribe los datos de la tarjeta (A5.6) y la pasarela autoriza el cobro.
    3. El sistema crea la suscripción y emite las claves de producción y de pruebas.
    4. El sistema publica en Redis las claves (su hash) y la suscripción.
    5. El portal muestra las dos claves completas **una sola vez** (A5.4b).
- **Flujos alternos:**
    - **2a.** La tarjeta es rechazada: el mismo formulario muestra el error y no se crea nada.

    - **1a.** El consumidor ya tiene una suscripción en esa API: el flujo pasa a ser un cambio de plan (B2.7), con las reglas de RF-25.
- **Requisitos:** RF-19, RF-20, RF-25, RF-26 · **Pantallas:** A5.4, A5.6, A5.4b, B2.7.

CU-13 Gestionar claves

- **Actores:** consumidor (rotar y revocar las suyas) y proveedor (revocar las de sus consumidores).
- **Flujo principal (rotar):**
    1. El consumidor pulsa "Rotar" en una clave activa y confirma (B2.4).
    2. El sistema emite una clave nueva, pone la anterior en estado `rotada` con 24 horas más de vigencia y actualiza Redis.
    3. La clave nueva se muestra una sola vez (B2.5).
- **Flujo principal (revocar):**
    1. El actor pulsa "Revocar" y confirma (A4.3b o B2.6).
    2. El sistema marca la clave como `revocada`, la elimina de Redis y lo registra en la bitácora (`clave.revocada_por_consumidor` o `clave.revocada_por_proveedor`).
    3. A partir de ese momento, la compuerta responde 401.
- **Flujos alternos:** si la clave está revocada, el consumidor puede pulsar "Emitir una clave nueva", que se muestra una sola vez. Solo se emite si la suscripción no tiene otra clave activa de ese tipo; si la tiene, responde 409 `clave_activa_existente`. Rotar una clave que no está activa (ya rotada o revocada) responde 422 `clave_no_rotable`. Si al rotar hay otra clave rotada del mismo tipo que sigue dentro de sus 24 horas, esa deja de funcionar en ese momento, para que no coexistan más de dos claves del mismo tipo (RF-27). Revocar una clave ya revocada no cambia nada.
- **Qué claves se muestran** (A4.3 y B2.3): las activas, las rotadas mientras duran sus 24 horas y, por cada tipo sin clave activa, la última revocada, para que se vea que se puede emitir otra. No se muestran las de suscripciones finalizadas. Van primero las de producción y luego las de pruebas; dentro de cada tipo, activa, rotada y revocada. A4.3 agrupa por consumidor, en el orden en que contrataron.
- **Bitácora** (10 §7): la rotación y las dos revocaciones quedan registradas, con los textos "Boutique Cayalá rotó su clave de producción en la API de Cotización de Envíos", "Boutique Cayalá revocó su clave de producción en la API de Cotización de Envíos" y "Revocó la clave de pruebas de Tienda Sololá en la API de Cotización de Envíos".
- **Requisitos:** RF-26, RF-27, RF-28 · **Pantallas:** A4.3, A4.3b, B2.3 a B2.6.

CU-14 Consumir la API a través de la compuerta

- **Actor:** consumidor (su sistema) y la compuerta.
- **Flujo principal:** la petición atraviesa la tubería de filtros de 08 §3, llega al origen y la respuesta vuelve con las cabeceras de cuota.
- **Flujos alternos:** los rechazos 401, 403, 404 y 429, y los errores 502 y 504, que se describen en 08 §4.
- **Requisitos:** RF-29 a RF-33, RF-45 · **Pantallas:** —.

CU-15 Consultar consumo, consumidores y pagos

- **Actores:** proveedor y consumidor.

- **Flujo principal:** el actor elige el periodo o la API, y el sistema muestra las métricas consolidadas y el historial de pagos.
- **Requisitos:** RF-21, RF-35, RF-36, RF-37 · **Pantallas:** B1.1 a B1.3, B2.1, B2.2.

CU-16 Renovar, poner en gracia y suspender suscripciones

- **Actor:** sistema (trabajador), cada minuto.
- **Flujo principal:**
  1. El trabajador toma las suscripciones con `fin <= ahora` en estado `activa`.
  2. Si la suscripción tiene un `plan_siguiente_id`, lo aplica.
  3. Si el plan es gratuito, abre un ciclo nuevo sin cobrar. Si es de pago, cobra al medio de pago registrado.
  4. Si el cobro se autoriza, abre un ciclo nuevo, reinicia la cuota y actualiza Redis.
- **Flujos alternos:**
  - **3a.** El cobro se rechaza o no hay medio de pago: la suscripción pasa a `en_gracia`, con `gracia_hasta = fin + 7 días`, y se pone en la cola el correo.
  - **3b.** El plan es Prueba: pasa directamente a `en_gracia` y se avisa por correo.
  - **5.** Cuando llega `gracia_hasta` sin pago, la suscripción pasa a `suspendida`, Redis se actualiza (la compuerta responde 403) y se pone en la cola el correo.
- **Requisitos:** RF-22, RF-23, RF-44, RF-46 · **Pantallas:** B1.4, B2.3.

CU-17 Administrar planes de plataforma

- **Actor:** administrador. Crea, edita y desactiva planes (RF-17). · **Pantallas:** A6.1.

CU-18 Suspender o reactivar una organización

- **Actor:** administrador.
- **Flujo principal:**
  1. El administrador confirma la suspensión (A6.2b).
  2. El sistema pone `estado_admin = suspendida`, actualiza Redis, registra la acción en la bitácora y avisa al propietario.
  3. La compuerta responde 403 en menos de 10 segundos.
  4. Reactivar la organización revierte todo lo anterior.
- **Requisitos:** RF-38, RF-41 · **Pantallas:** A6.2, A6.2b.

CU-19 Revertir un pago

- **Actor:** administrador.
- **Flujo principal:** el administrador confirma (A6.3b). La pasarela simulada devuelve el monto, el pago pasa a `revertido` y, si cubría el ciclo vigente, la suscripción entra en gracia. Queda en la bitácora.
- **Requisitos:** RF-24, RF-41 · **Pantallas:** A6.3, A6.3b.

CU-20 Atender casos de soporte

- **Actores:** proveedor, soporte y administrador.
- **Flujo principal:**
  1. El proveedor abre un caso con un asunto, una descripción y, opcionalmente, la API afectada (A7.1).
  2. El soporte lo ve en A6.4, se lo asigna y consulta los datos de la organización en solo lectura.
  3. El soporte responde; el proveedor recibe un correo y ve la respuesta en A7.2.
  4. Cualquiera de las dos partes responde hasta que el soporte cierra el caso.
- **Flujos alternos:**
  - **1a.** El soporte registra el caso a nombre de la organización, por ejemplo después de una llamada.
- **Requisitos:** RF-40, RF-46 · **Pantallas:** A7.1, A7.2, A6.4, A6.4b.

CU-21 Administrar cuentas de plataforma

- **Actor:** administrador. Crea cuentas de administración o de soporte (reciben un enlace para definir su contraseña) y las desactiva o reactiva (RF-42). · **Pantallas:** A6.5.

CU-22 Consultar el estado y la bitácora

- **Actores:** administrador y soporte. Ven el estado de los componentes con la latencia p95 de la compuerta, y la bitácora filtrada por fechas (RF-39, RF-41). · **Pantallas:** B3.1, B3.2.

CU-23 Invitar consumidores

- **Actor:** propietario o editor.
- **Flujo principal:** el actor escribe el correo del consumidor y envía la invitación (vence a los 7 días). La lista muestra las invitaciones pendientes de la organización, que se pueden cancelar o reenviar desde cualquiera de sus APIs. Si el correo ya tiene cuenta de consumidor o una invitación vigente en la organización, no se crea otra: responde `409 consumidor_existente` o `409 invitacion_pendiente`, respectivamente.
- **Requisitos:** RF-05 · **Pantallas:** B1.5.

CU-24 Explorar la documentación y probar en la consola

- **Actor:** visitante o consumidor.
- **Flujo principal:** el actor navega por las rutas expuestas, pega su clave de pruebas en la consola, completa los parámetros y envía la petición. La respuesta real se muestra con su código.
- **Requisitos:** RF-16, RF-45 · **Pantallas:** A5.0, A5.1, A5.2.

CU-25 Consolidar el consumo

- **Actor:** sistema (trabajador), cada 10 segundos. Sigue el algoritmo idempotente de 08 §7 (RF-34).

CU-26 Enviar correos

- **Actor:** sistema (trabajador), cada 5 segundos. Toma los correos `pendiente` de `correo_saliente`, los envía por SMTP (a Mailpit en el entorno simulado) y los reintenta hasta 5 veces, con espera exponencial (RF-46).